Sécurité, protection des données et qualité des contenus

Hébergement, protection et maintenance de la plateforme de formation RALK (app.ralk.io). Cette fiche présente les mesures techniques et organisationnelles en place à la date d'émission.

HÉBERGEMENT ET ARCHITECTURE

- **Frontend** (ralk.io, app.ralk.io) : Vercel
- **API backend :** Railway, région de déploiement europe-west4 (UE)
- **Base de données :** MongoDB Atlas (comptes utilisateurs, données de formation, certificats)
- Tous les services sont fournis en HTTPS (TLS)
- Le backend n'accepte les requêtes navigateur que des origines RALK configurées (liste CORS)

EN-TÊTES DE SÉCURITÉ (APP.RALK.IO)

- Strict-Transport-Security (HSTS, 1 an, sous-domaines inclus)
- Content-Security-Policy, intégration en cadre bloquée (frame-ancestors 'none')
- X-Frame-Options : DENY · X-Content-Type-Options : nosniff
- Referrer-Policy et Permissions-Policy (caméra, micro, géolocalisation désactivés)

AUTHENTIFICATION ET SESSIONS

- Connexion avec un compte professionnel Google ou Microsoft (OAuth 2.0 avec PKCE)
- Collaborateurs : liens de connexion à usage unique par e-mail, valables 20 minutes, conservés uniquement sous forme de hash
- Administrateurs : second facteur par code à usage unique envoyé par e-mail à chaque connexion (valable 10 minutes, tentatives limitées)
- Les mots de passe, le cas échéant, sont conservés uniquement sous forme de hash Argon2
- Jetons de session dans des cookies httpOnly, avec expiration
- Limitation du débit (rate limiting) sur la connexion et les autres points d'accès sensibles

CONTRÔLE D'ACCÈS ET PISTE D'AUDIT

- Accès par rôle : collaborateur, administrateur client, administrateur de la plateforme RALK (super-admin)
- Données conservées par organisation ; les sessions des administrateurs clients sont liées à leur propre organisation
- Journal d'audit des événements de sécurité (p. ex. connexions, codes erronés, émission de certificats) avec horodatage, auteur et hash d'intégrité SHA-256
- Les certificats portent un identifiant unique et un hash d'intégrité et sont vérifiables en ligne

PROTECTION DES DONNÉES (RGPD)

- RALK est établie en Allemagne ; le Règlement général sur la protection des données de l'UE s'applique
- RALK traite les données personnelles des utilisateurs en qualité de sous-traitant pour le compte du Client, dans le cadre d'un accord de traitement des données (conditions de licence, article 8)
- Droits des personnes : accès, rectification, effacement, limitation, portabilité, opposition (art. 15 à 21 RGPD)
- Fin du contrat : export des données de formation pendant 30 jours, puis suppression sauf obligation légale de conservation (conditions de licence, 7.3)
- Autorité de contrôle : Landesbeauftragter für den Datenschutz und die Informationsfreiheit Baden-Württemberg
- Politique de confidentialité : check.ralk.io/privacy

SOUS-TRAITANTS ULTÉRIEURS

Prestataire	Finalité
Vercel Inc. (États-Unis)	Hébergement frontend
Railway (États-Unis)	Hébergement de l'API backend
MongoDB Atlas / MongoDB Inc. (États-Unis)	Base de données : comptes, données de formation, certificats
Anthropic PBC (États-Unis)	API de modèle d'IA pour les contenus de formation personnalisés
OpenAI / DALL·E (États-Unis)	Images des scénarios de formation
Cloudflare R2 (Cloudflare Inc., États-Unis)	Stockage des images de formation
Resend (États-Unis)	E-mails transactionnels (liens de connexion, notifications)
FormSubmit.co	Relais du formulaire du Quick-Check
Google Ireland Ltd. (Google LLC, États-Unis)	Mesure des conversions publicitaires sur ralk.io, sur consentement

Transferts encadrés par des clauses contractuelles types ou des décisions d'adéquation le cas échéant (politique de confidentialité, section 6).

QUALITÉ DES CONTENUS

Le contenu de formation est élaboré sous la responsabilité des experts en conformité et criminalité financière de RALK, sur la base des normes du GAFI et de la réglementation applicable. RALK utilise l'intelligence artificielle comme outil pour préparer les contenus et les adapter à la fonction, au secteur et au pays de chaque apprenant. Les modules, scénarios et la logique d'évaluation sont revus par les experts de RALK et font l'objet d'une revue régulière. Le contenu constitue un support de formation et non un conseil juridique.

Conditions de licence, article 3.2.

PRÉVU Test d'intrusion indépendant, chaque année